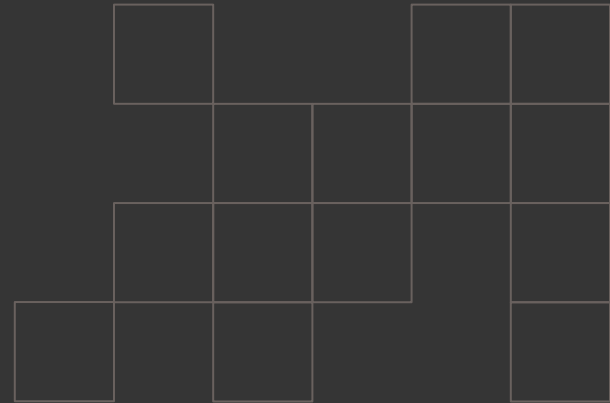


Rate Limiting System

Jorge Estrada



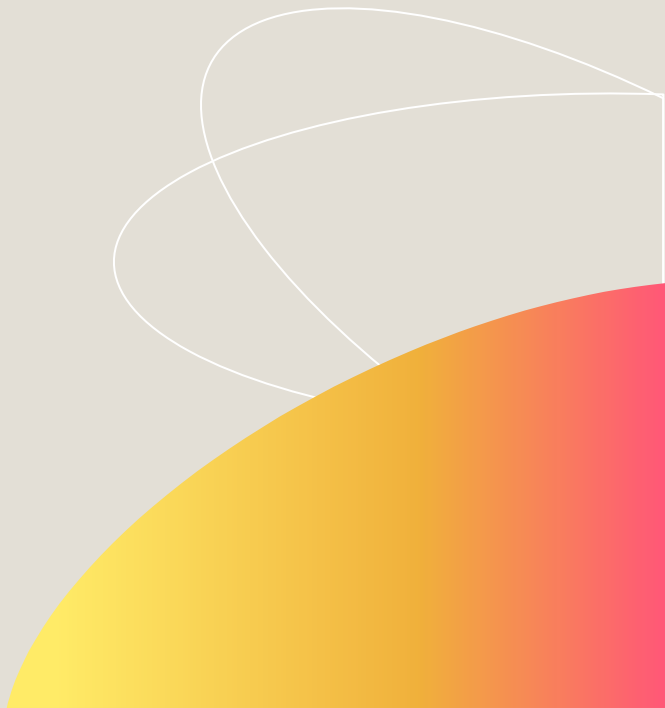


What is Rate Limiting & Why It Matters

- Rate limiting controls how many requests a user can send in a certain time
 - It helps prevent abuse from bots and automated scripts
 - Without it, one user can overload a server with too many requests
 - This can lead to slow performance or even system crashes
 - It is commonly used to protect logins, APIs, and web applications
 - Overall, it helps keep systems stable and secure
- 

Problem

- Bots and automated scripts can send a large number of requests in a short time
- This kind of traffic can overwhelm a server and slow it down for real users
- In some cases, it can even cause the system to crash or go offline
- Attacks like DoS, brute force, and scraping all rely on this behavior
- Many systems do not have a way to detect or control this traffic early
- This makes it easy for attackers to abuse the system without being stopped

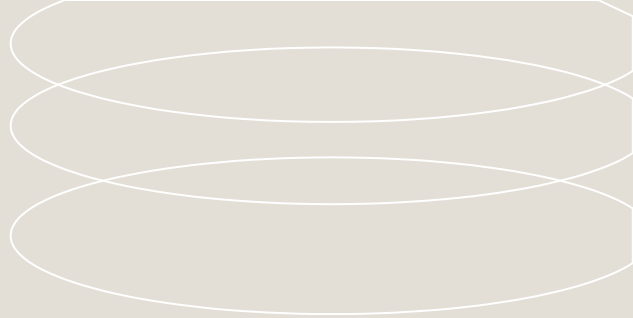


Solution

- The system tracks how many requests each IP address sends over time
- It uses a sliding time window to monitor request activity in real time
- Limits are set to define what is considered normal and abnormal behavior
- When traffic starts increasing, it is flagged as suspicious but still allowed
- If the request count keeps rising, the system blocks further requests
- Blocked users receive a 429 error to stop excessive traffic
- All requests and decisions are logged for monitoring and analysis

How it works

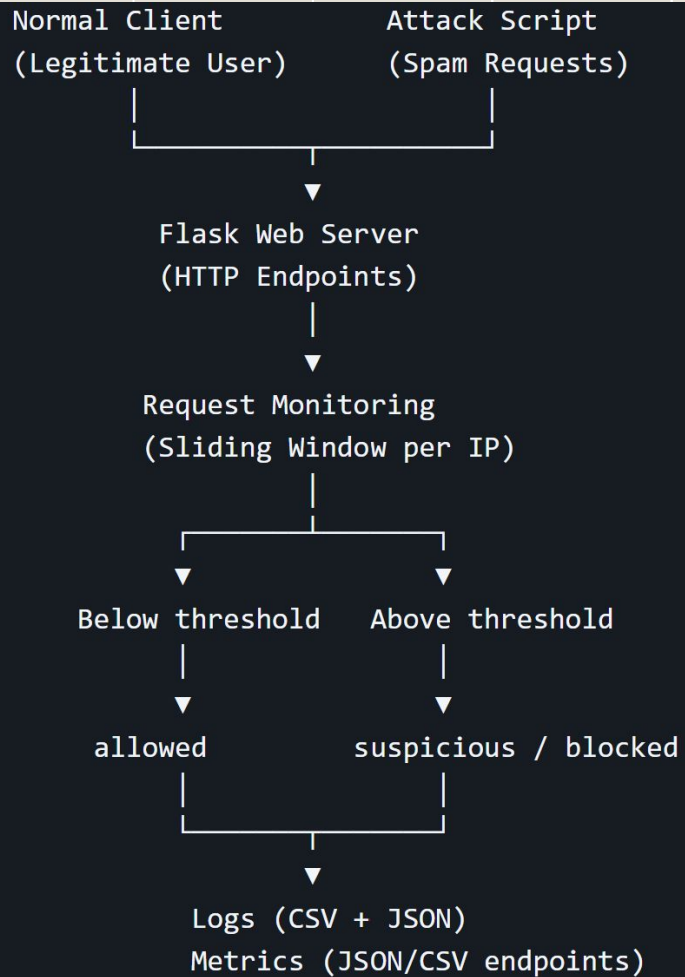
- Each IP has a list of request timestamps
- Old requests (over 60 seconds) are removed
- New request is added to the list
- Total requests are counted
- Compared against thresholds to decide action



Thresholds

- 1–14 requests → Normal (allowed)
- 15–20 requests → Suspicious (still allowed)
- 21+ requests → Blocked (429 error)
- Two-step system helps observe before blocking
- Makes it easier to adjust thresholds later





System Architecture

Methods

- Python dictionary stores timestamps per IP
- Old timestamps removed on every request
- Logs saved in CSV with HMAC signature
- Attack simulator sends 25 requests
- Metrics collected after test run

Metrics Collected

- Total allowed requests
- Total suspicious requests
- Total blocked requests
- Number of active clients
- Request count at each step
- HMAC used to verify log integrity

Test	Type	Result
test_home_returns_200	Happy path	PASS
test_blocked_after_limit	Negative	PASS
test_health_endpoint	Functional	PASS
test_metrics_endpoint	Functional	PASS
test_metrics_csv_endpoint	Functional	PASS
test_data_endpoint	Functional	PASS
test_unknown_route_returns_404_not_blocked	Edge case	PASS
test_exactly_at_limit_is_allowed	Edge case	PASS
test_x_forwarded_for_ip_respected	Edge case	PASS
test_suspicious_threshold_tracked	Edge case	PASS
test_blocked_requests_increments_counter	Negative	PASS
test_csv_log_created_with_headers	Integration	PASS

Testing

- Tested normal requests staying under the limit (returns 200 OK)
- Tested requests at the exact threshold to confirm correct behavior
- Tested blocking after limit is exceeded (returns 429)
- Verified suspicious traffic is tracked before blocking
- Tested metrics endpoints to confirm correct data output
- Checked that logs are created and include valid HMAC signatures
- Covered edge cases like unknown routes and header handling
- Achieved 97% code coverage with all tests passing

```
1 timestamp,client_ip,path,status>window_count,hmac
76 2026-04-27T06:36:41.640325+00:00,172.19.0.1,/data,blocked,34,b6a94eea417de040
77 2026-04-27T06:36:41.675160+00:00,172.19.0.1,/data,blocked,35,4e448b4f221272b7
78 2026-04-27T06:36:41.707344+00:00,172.19.0.1,/data,blocked,36,2b5c320e348053aa
79 2026-04-27T06:36:41.760051+00:00,172.19.0.1,/data,blocked,37,615e583e6ed40d49
80 2026-04-27T06:36:41.808133+00:00,172.19.0.1,/data,blocked,38,0030f3e29a8a4efc
81 2026-04-27T06:36:41.856627+00:00,172.19.0.1,/data,blocked,39,0713661e3dd30b35
82 2026-04-27T06:36:41.905725+00:00,172.19.0.1,/data,blocked,40,eef21c23094775fe
83 2026-04-27T06:36:41.956453+00:00,172.19.0.1,/metrics,blocked,41,2291c57d4157d5e5
84 2026-04-27T06:38:41.193016+00:00,172.19.0.1,/health,allowed,1,8cd2d6d1eef0682b
85 2026-04-27T06:39:22.309237+00:00,172.19.0.1,/health,allowed,2,2284a2d8727d19de
86 2026-04-27T06:39:22.863666+00:00,172.19.0.1,/health,allowed,3,79de037b78d50573
87 2026-04-27T06:39:59.925055+00:00,172.19.0.1,/,allowed,1,09acd01f0d7ec85b
88 2026-04-27T06:40:00.063523+00:00,172.19.0.1,/,allowed,2,258a683a8f4c09ec
89 2026-04-27T06:40:00.195714+00:00,172.19.0.1,/,allowed,3,aae7e1ae9efbfa4e
90 2026-04-27T06:40:00.326427+00:00,172.19.0.1,/,allowed,4,5275764426f8bdda
91 2026-04-27T06:40:00.461162+00:00,172.19.0.1,/,allowed,5,770ae41c77587440
92 2026-04-27T06:40:00.594624+00:00,172.19.0.1,/,allowed,6,2a73aec2bb3917a1
93 2026-04-27T06:40:00.727657+00:00,172.19.0.1,/,allowed,7,0f553c4407e97a1f
94 2026-04-27T06:40:00.850666+00:00,172.19.0.1,/,allowed,8,08d18ef9e46ebe87
95 2026-04-27T06:40:00.990143+00:00,172.19.0.1,/,allowed,9,fd4e1bca85f18f16
96 2026-04-27T06:40:01.129712+00:00,172.19.0.1,/,allowed,10,edff61fbdc7cb781
97 2026-04-27T06:40:02.258806+00:00,172.19.0.1,/data,allowed,11,870f4243fb2a35ed
98 2026-04-27T06:40:02.269489+00:00,172.19.0.1,/data,allowed,12,94cec9bd946bc0e4
99 2026-04-27T06:40:02.280784+00:00,172.19.0.1,/data,allowed,13,69c99959fcd319e7
100 2026-04-27T06:40:02.293275+00:00,172.19.0.1,/data,allowed,14,e3a39f84db22a53b
101 2026-04-27T06:40:02.325891+00:00,172.19.0.1,/data,suspicious,15,06f3b2df62d9d099
102 2026-04-27T06:40:02.375001+00:00,172.19.0.1,/data,suspicious,16,9c6deb220a6df961
103 2026-04-27T06:40:02.425202+00:00,172.19.0.1,/data,suspicious,17,403b47076014f3e8
104 2026-04-27T06:40:02.457559+00:00,172.19.0.1,/data,suspicious,18,c995623507509e44
105 2026-04-27T06:40:02.478693+00:00,172.19.0.1,/data,suspicious,19,871b863662c7a057
106 2026-04-27T06:40:02.499197+00:00,172.19.0.1,/data,suspicious,20,bab1613b199ed62e
107 2026-04-27T06:40:02.540638+00:00,172.19.0.1,/data,blocked,21,d46f6d5acbc54f03
108 2026-04-27T06:40:02.574808+00:00,172.19.0.1,/data,blocked,22,4f8264c70d7fef21
109 2026-04-27T06:40:02.609949+00:00,172.19.0.1,/data,blocked,23,46d44fe2d05f95dc
110 2026-04-27T06:40:02.642240+00:00,172.19.0.1,/data,blocked,24,fa5e5b44200918cd
111 2026-04-27T06:40:02.677770+00:00,172.19.0.1,/data,blocked,25,3c9a7d0f5a60c234
```

Limitations

- Data stored in memory only (resets on restart)
- No shared state between multiple containers
- Can miss slower attacks under the threshold
- Depends on proper proxy configuration
- No long-term blocking of attackers

Future Work

- Use Redis for shared and persistent storage
- Add a persistent denylist for attackers
- Adjust thresholds based on real data
- Capture PCAP data for deeper analysis
- Improve logging format (JSONL)



Thank you